

정보보안점검 지침



주식회사 모인

개정 이력

[illegible]

정보보안 점검 지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 “회사”라 한다)의 정보보안 점검, 내부감사 및 자체 보안성심의에 관한 사항을 규정하는 정책시행 문서로서 정보보호 정책 및 지침의 사항이 적절하게 수행되고 있는지를 점검하기 위한 기준으로써 활용함을 그 목적으로 한다.

제2조(적용 범위) 이 지침은 회사의 모든 인력과 정보자산을 대상으로 한다.

제3조(용어의 정의) 이 지침은 다음 각 호의 용어 정의를 따른다.

1. “정보보안 점검(이하 “점검”이라 한다)”이란 회사의 정보자산 및 자원에 대한 보안점검을 통하여 취약점 식별 및 원인을 파악하고, 보호조치를 적용함으로써 서비스상에 발생할 수 있는 보안위협 요소를 사전에 예방하는 활동을 의미한다.
2. “정보보안 내부감사(이하 “내부감사”라 한다)”란 정보보호관리체계를 안정적으로 운영하고 있음을 보증하기 위해 소관부서에서 인터뷰, 문서검토, 실사, 진단 및 분석 등 다양한 방법으로 증거를 수집하고 분석하여 결과를 보고하는 활동을 의미한다.
3. “자체 보안성 검토·심의(이하 “보안성 검토·심의”라 한다)”란 전자금융서비스를 수행하기 위한 전산프로그램 설치 및 변경, 신규 전자금융업무 수행 등의 행위에 대한 전자금융 부정 사용 예방, 금융정보 유출방지 등의 적정성에 대해 자체적으로 보안대책을 수립하고, 감독기관에게 보안성을 심의하는 제도를 의미한다.

제2장 역할 및 책임

제4조(정보보호최고책임자)

- 1 정보보호최고책임자(이하 “CISO”라 한다)는 점검, 내부감사, 보안성 검토·심의 업무에 대한 총괄 책임을 가진다.
- 2 CISO는 정보보호 담당자의 점검, 내부감사, 보안성 검토·심의 업무 수행에 대한 활동내역을 검토하여야 하며, 해당 업무에 대하여 집행할 책임이 있다.
- 3 CISO는 점검, 내부감사, 보안성 검토·심의와 관련하여 발생하는 이슈를 정보보호위원회 안건으로 상정할 수 있다.

제5조(정보보호 담당자)

- 1 정보보호 담당자는 점검, 내부감사, 보안성 검토·심의에 따른 수행결과와 이 과정에서 발생하는 보안이슈 등에 대하여 CISO에게 보고하여야 한다.
- 2 정보보호 담당자는 전문적인 기술이 필요한 경우 내·외부 전문 인력을 포함하여 업무를 수행할 수 있다.

제6조(피 점검 부서)

- 1 피 점검부서는 점검업무의 원활한 수행을 위하여 소관부서로부터 각종 자료의 제시 및 기타 요구가 있을 때에는 적극 협조하여야 한다.
- 2 피 점검부서는 정당한 사유 없이 소관부서의 자료 제출, 출석 및 설명 요구에 대하여 거부할 수 없다.

제7조(사업추진부서)

- 1 신규 정보화 사업을 추진하는 사업추진부서는 보안성 검토·심의 진행에 따른 실무부서로서 추진 사업에 대한 보안대책을 수립하여야 한다.
- 2 사업추진부서는 보안성 검토·심의 결과에 따라 개선이 필요한 경우 이행계획을 수립하고, 개선사항을 반영하여야 한다.

제3장 점검 및 내부감사 계획 수립

제8조(연간 계획수립)

- 1 소관부서는 매년 점검 및 내부감사를 실시하기 위하여 대상 및 범위, 수행일시, 수행기준, 수행방법 등에 대한 연간 계획을 수립하여야 한다.
- 2 소관부서는 정보보안 사고 징후, 정보보안 사고 발생 등 중대한 사안이 발생되거나, 점검 및 내부감사가 필요하다고 인정되는 경우 연간 계획과 별도로 점검 및 내부감사를 실시할 수 있다.

제4장 정보보안 점검

제9조(점검의 범위와 대상) 소관부서는 정보보호 정책과 관련된 법적 요구사항에 근거하여 점검을 수행하며, 다음 각 호에 대해서는 연간 계획 수립 시 반드시 포함하여 점검을 수행한다.

- 1) 전자금융기반시설 보안 취약점 분석·평가에 관한 사항
- 2) 정보보안점검의 날 관련 세부사항에 대한 운영현황
- 3) 제1호의 대상 외 정보시스템 취약점 진단에 관한 사항
- 4) 발견된 취약점의 보완조치계획 또는 위험평가에 따라 수립한 위험조치계획

제10조(기반시설 보안 취약점 분석·평가)

- 1 소관부서는 전자금융기반시설을 대상으로 최소 연 1회 이상(공개용 웹서버의 경우 반기 1회) 취약점 분석·평가를 수행한다. 다만, 다음 각 호의 어느 하나에 해당하는 경우에는 지체없이 취약점 분석·평가를 한다.
 - 1) 침해사고가 발생하여 그 피해 및 피해 확산을 방지하기 위한 긴급한 조치가 필요한 경우
 - 2) 정보처리시스템이나 인터넷 홈페이지 구축 등 정보기술부문 관련 사업을 실시하였거나, 정보기술부문의 기능개선 또는 변경을 수행한 경우
- 2 취약점 분석·평가를 수행하는 자체전담반은 CISO를 포함하여 다음 사항을 고려하여 5인 이상으로 구성한다. 다만, 외부의 평가전문기관에 위탁하여 처리하는 경우에는 자체전담반을 구성하지 아니할 수 있다.
 - 1) 구성원 중 30%이상은 이상은 「정보보호산업의 진흥에 관한 법률 시행규칙」 제8조의 정보보호 전문서비스 기업 지정기준에서 정한 고급 기술인력 이상의 자격을 갖춘 자
- 3 취약점 분석·평가 결과에 따라 발견된 취약점에 대한 이행계획을 수립하고, 「정보보호조직지침」 제9조에 따라 정보보호위원회는 취약점분석·평가 결과 및 이행계획에 대해 심의·의결한다.
- 4 이행계획에 따라 취약점의 제거 또는 이에 상응하는 조치를 수행하여야 하며, 이행계획의 시행 결과 및 부득이하게 조치가 불가능한 취약점의 경우에는 대표이사로부터 승인을 득하여야 한다.
- 5 회사는 취약점 분석·평가 종료 후 30일 이내에 다음 각 호의 사항이 포함된 결과보고 및 보완조치 이행계획서를 금융위원회에 제출한다.
 - 1) 취약점 분석·평가의 사유, 대상, 기간 등 실시개요
 - 2) 취약점 분석·평가의 세부 수행방법
 - 3) 취약점 분석·평가 결과
 - 4) 취약점 분석·평가 결과에 따른 필요한 보완 조치의 이행계획
 - 5) 전자금융기반시설의 취약점 분석·평가 결과보고서

제11조(정보보안점검의 날 보안점검) CISO는 매월 첫째주 월요일을 정보보안점검의 날로 지정하고, 금융감독원장이 정하는 정보보안 점검항목에 대한 준수여부를 점검하여 그 결과 및 보완계획을 대표이사에게 보고한다.

제12조(이행점검)

- 1 CISO는 발견된 취약점의 보완조치계획 또는 위험평가에서 수립한 위험조치계획에 근거하여 개선사항의 반영여부에 대해 이행점검을 수행한다.
- 2 이행점검 결과에 따라 미흡사항이 발견된 피 점검부서는 보완조치계획 또는 위험조치계획을 재

수립하고, 다음 점검 시 이를 반영하여 점검을 수행한다.

제5장 정보보안 내부감사

제13조(내부감사의 범위와 대상)

- 1 소관부서의 내부감사는 관련 법규의 준수여부를 포함하여 (개인)정보보호관리체계 운영 활동에 대한 준수여부를 감사하며, 다음 각 호에 대해서는 최소 연 1회 이상 감사를 수행한다.
 - 1) 전자금융거래법상의 이행실태 점검
 - 2) 개인정보 내부 관리계획의 이행실태 점검
 - 3) 임직원의 신용정보보호 관련 법령 및 규정 준수 여부 점검
 - 4) 그 외 CISO가 필요하다고 인정하는 인증요건 세부사항에 대한 운영현황
- 2 제1항 제1호에 따른 전자금융거래법 상의 이행실태 점검의 경우 제9조 제1호의 점검 결과를 활용하거나, 감독기관의 검사 대응 또는 최신 보안 이슈에 대비하기 위한 범위로 한정하여 감사를 수행할 수 있다.
- 3 제1항 제2호 및 제3호에 따른 신용정보보호 관련 법령 및 개인정보 내부 관리계획 등 내부 규정의 이행실태 점검의 경우 접근권한 관리, 접속기록 보관 및 점검, 암호화 조치, 개인(신용)정보의 업무 처리 적정성 등에 대하여 감사를 수행하여야 한다.
- 4 제1항 제4호에 따른 인증요건은 ISMS-P, ISO/IEC 27001/27701, SOC2, PCI-DSS 등을 의미하며, CISO가 필요하다고 인정하는 경우에 감사를 수행할 수 있다.
- 5 제1항 제1호, 제2호 및 제3호에 따른 점검의 결과는 CISO의 승인을 득하여 대표이사에게 보고하여야 한다.

제14조(내부감사 인력의 자격기준)

- 1 내부감사인력은 회사의 업무 이해도가 높고, 정보보호 관련 업무를 수행한 경험이 있는 자로 지정한다.
- 2 내부감사에 관한 전문적인 기술이 필요한 경우에는 내·외부의 전문 인력을 포함할 수 있다.

제15조(내부감사의 실시)

- 1 정보보호 담당자는 사전에 감사 실시를 위한 내부감사 대상 및 범위를 피 감사부서에 통보하고, 필요한 경우 사전에 관련 자료의 제출을 요구할 수 있다.
- 2 정보보호 담당자는 감사 시 피 감사부서를 대상으로 인터뷰, 문서검토, 현장 실사를 통해 보안감사를 실시하여야 한다.
- 3 피 감사부서는 감사 실시 시 정보보호 담당자로부터 요청을 받은 때에는 지체 없이 자료제출 또는 답변을 하여 보안감사의 원활한 수행에 협조하여야 한다.

제16조(내부감사 증거의 수집)

- 1 정보보호 담당자는 피 감사부서에 적용되는 정보보호 정책 및 지침의 항목에 대하여 이행하고 있음을 확인하기 위한 감사증거를 수집하여야 한다.
- 2 정보보호 담당자는 감사 항목에 대하여 담당자 인터뷰, 시스템 설정 및 운영 결과 검토, 취약점 진단 및 분석 등을 통해 필요한 감사 증거(Audit Trail)를 확보하여야 한다.

제17조(내부감사 결과의 보고)

- 1 정보보호 담당자는 내부감사 실시 후 정보보호 감사보고서를 작성하여 CISO에게 제출하여야 한다.
- 2 정보보호 담당자는 정보보호 감사 수행 중 중대한 정보보호 사고를 발견한 경우 지체 없이 CISO에게 보고하여야 한다.
- 3 정보보호 담당자는 보안감사 지적 사항에 대하여 피 감사부서에 시정 요청을 하여야 하며, 시정 요청을 통보받은 피 감사부서는 보안감사 결과 지적 사항에 대하여 조치를 수행한다.
- 4 정보보호 담당자는 기술적 점검결과 발견된 취약성에 대한 대응방안 및 조치를 문서화하고 개선사항을 이행하여야 하며, CISO에게 보고하여야 한다.
- 5 정보보호 감사보고서는 외부로 유출되지 않도록 주의하며, 배포 및 보고 대상자의 선정에 주의를 기울여야 한다.
- 6 정보보호감사의 일부를 외부 전문가를 활용하여 시행한 경우 외부 전문가에 의해 시행된 범위를 명시하여야 한다.

제6장 자체 보안성 검토·심의

제18조(자체 보안성 검토·심의 대상)

- 1 회사는 다음 각 호의 행위를 하고자 하는 경우 보안성 심의를 실시하여야 한다.
 - 1) 정보통신망을 이용하여 이용자를 대상으로 신규 전자금융업무 수행
 - 2) 복수의 금융회사 또는 전자금융업자가 공동으로 전자금융거래 관련 표준 제정
- 2 회사는 다음 각 호의 행위를 하고자 하는 경우 보안성 검토를 실시하여야 한다.
 - 1) 전자금융거래에 사용되는 전산프로그램을 정보시스템에 설치 및 변경
 - 2) 내부망 또는 폐쇄망을 인터넷 또는 다른 정보통신망과 연동하는 사업
 - 3) 전산센터(전산실) 구축 또는 IDC센터 신규 이용
 - 4) 기타 상위 감독기관 및 CISO가 필요하다고 인정하는 경우

제19조(자체 보안성 검토·심의 요청)

- 1 사업추진부서는 정보화 사업 계획 수립 시 보안성 검토·심의 여부를 체크하고, 보안성 검토·심의 대상이라고 판단되는 경우 사업추진 계획서와 보안성 검토·심의 관련 자료를 소관부서에 제출한다.
- 2 정보보호 담당자는 사업추진부서가 제출한 자료를 근거로 보안성 검토·심의 대상여부를 최종 판단하여 사업추진부서에 통지한다.

제20조(자체 보안성 검토·심의 수행)

- 1 사업추진부서는 분석/설계 단계에서 소관부서와의 협조 하에 보안대책에 대한 적용방안을 설계서 등에 반영하고, 구현 시 이를 반영한다.
- 2 정보보호 담당자는 제1항의 보안대책 구현의 적정성을 검토하고, 사업추진부서와의 협조 하에 개선 또는 보완 필요 사항을 모두 반영하여 CISO에게 보고한다.
- 3 해당 사업이 제19조 제1항에 따른 보안성 심의 대상인 경우 자체 보안성심의 결과보고서를 작성하여 CISO의 승인을 득한 후 전자금융 업무가 제공 또는 시행된 날로부터 7일 이내 보안성 심의와 관련된 자료를 금융감독원에 제출한다.
- 4 금융감독원의 보안성 심의 결과에 대하여 개선이 요구되는 경우 이행계획을 수립하여 금융감독원에 제출한다.
- 5 사업추진부서는 보안성 검토·심의 결과에 대한 개선사항을 사업계획서에 반영한다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.